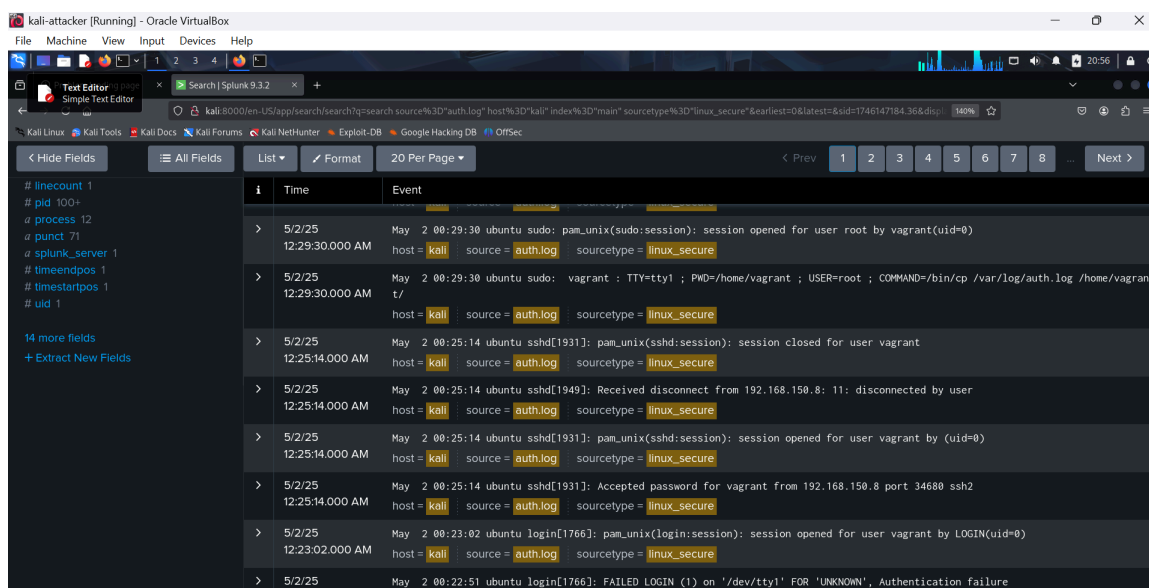


Phase 3 – Defensive Strategy Proposal

In this phase, we implemented a defensive strategy on the victim machine (Metasploitable3) to mitigate the previous attacks observed in Phase 2. The goal was to enhance system security and verify the effectiveness of the defense using testing and log analysis through Splunk.

Step 1: Identify the Attack

In this step, we used Splunk to analyze the uploaded auth.log file. From the log entries, we identified multiple SSH login activities, including both accepted and failed attempts.

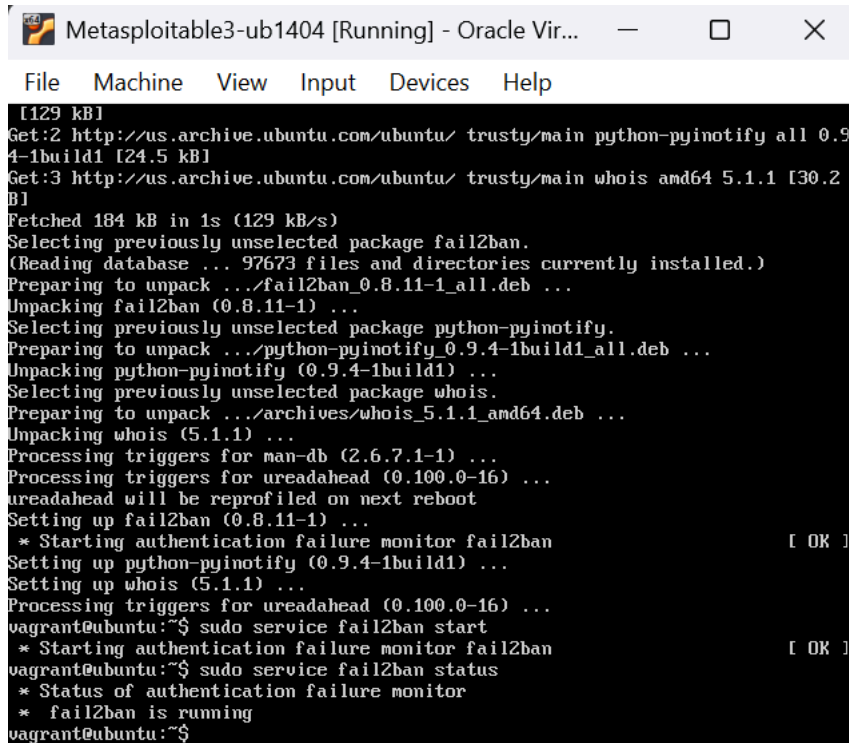


The screenshot shows a Splunk search interface with the following search query: `search source=auth.log host=kali index=main sourcetype=linux_secure`. The results are displayed in a table with columns for Time and Event. The events show various SSH login activities, including session openings, password acceptance, and session closures.

Time	Event
May 2 00:29:30	ubuntu sudo: pam_unix(sudo:session): session opened for user root by vagrant(uid=0)
May 2 00:29:30	ubuntu sudo: vagrant : TTY=ttty1 ; PwD=/home/vagrant ; USER=root ; COMMAND=/bin/cp /var/log/auth.log /home/vagrant/
May 2 00:25:14	ubuntu sshd[1931]: pam_unix(sshd:session): session closed for user vagrant
May 2 00:25:14	ubuntu sshd[1949]: Received disconnect from 192.168.150.8: 11: disconnected by user
May 2 00:25:14	ubuntu sshd[1931]: pam_unix(sshd:session): session opened for user vagrant by (uid=0)
May 2 00:25:14	ubuntu sshd[1931]: Accepted password for vagrant from 192.168.150.8 port 34680 ssh2
May 2 00:23:02	ubuntu login[1766]: pam_unix(login:session): session opened for user vagrant by LOGIN(uid=0)
May 2 00:22:51	ubuntu login[1766]: FAILED LOGIN (1) on '/dev/tty1' FOR 'UNKNOWN', Authentication failure

Step 2: Apply Defense Mechanism

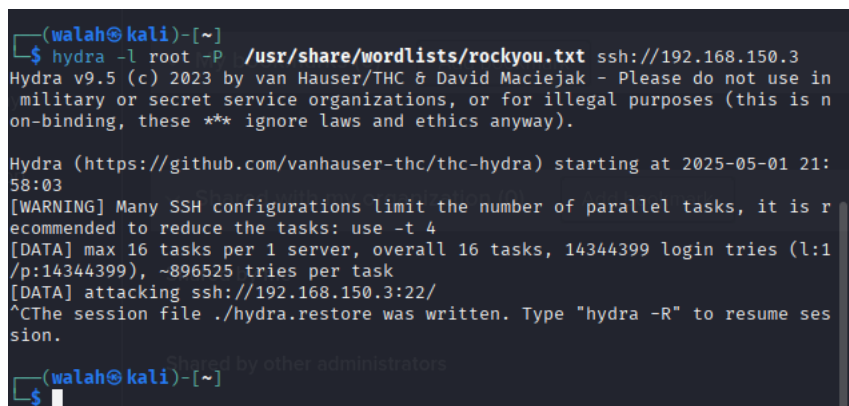
To mitigate SSH brute-force attempts, we implemented the Fail2Ban tool on the victim machine. This tool monitors log files and bans IPs that show malicious behavior.



```
[129 kB]
Get:2 http://us.archive.ubuntu.com/ubuntu/ trusty/main python-pyinotify all 0.9
4-1build1 [24.5 kB]
Get:3 http://us.archive.ubuntu.com/ubuntu/ trusty/main whois amd64 5.1.1 [30.2
B]
Fetched 184 kB in 1s (129 kB/s)
Selecting previously unselected package fail2ban.
(Reading database ... 97673 files and directories currently installed.)
Preparing to unpack .../fail2ban_0.8.11-1_all.deb ...
Unpacking fail2ban (0.8.11-1) ...
Selecting previously unselected package python-pyinotify.
Preparing to unpack .../python-pyinotify_0.9.4-1build1_all.deb ...
Unpacking python-pyinotify (0.9.4-1build1) ...
Selecting previously unselected package whois.
Preparing to unpack .../archives/whois_5.1.1_amd64.deb ...
Unpacking whois (5.1.1) ...
Processing triggers for man-db (2.6.7.1-1) ...
Processing triggers for ureadahead (0.100.0-16) ...
ureadahead will be reprofiled on next reboot
Setting up fail2ban (0.8.11-1) ...
* Starting authentication failure monitor fail2ban [ OK ]
Setting up python-pyinotify (0.9.4-1build1) ...
Setting up whois (5.1.1) ...
Processing triggers for ureadahead (0.100.0-16) ...
vagrant@ubuntu:~$ sudo service fail2ban start
* Starting authentication failure monitor fail2ban [ OK ]
vagrant@ubuntu:~$ sudo service fail2ban status
* Status of authentication failure monitor
* fail2ban is running
vagrant@ubuntu:~$
```

Step 3: Rerun the Attack

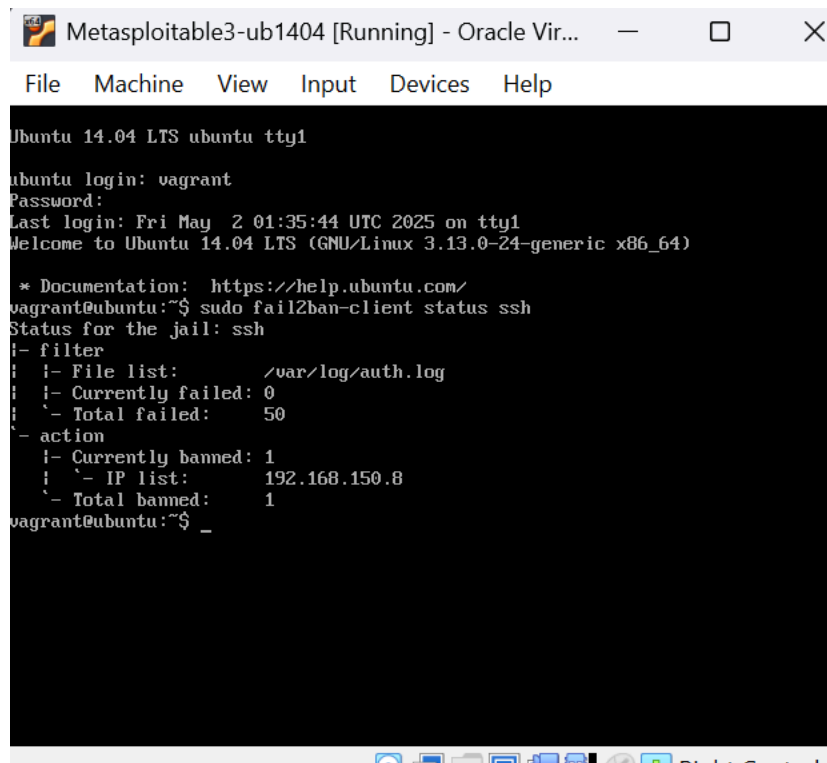
Before applying the defense mechanism, the attacker was able to perform multiple SSH login attempts against the victim. This can be seen in the Splunk logs showing repeated "Failed password" events. After configuring fail2ban on the victim machine, any repeated failed login attempts resulted in automatic banning of the attacker's IP. The final status of the jail confirms that the IP 192.168.150.8 was successfully banned after reaching 50 failed attempts.



```
(walah@kali)-[~]
$ hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://192.168.150.3
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-05-01 21:
58:03
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1
/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.150.3:22/
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume ses
sion.

(walah@kali)-[~]
$
```



```
Metasploitable3-ub1404 [Running] - Oracle Vir...
File Machine View Input Devices Help

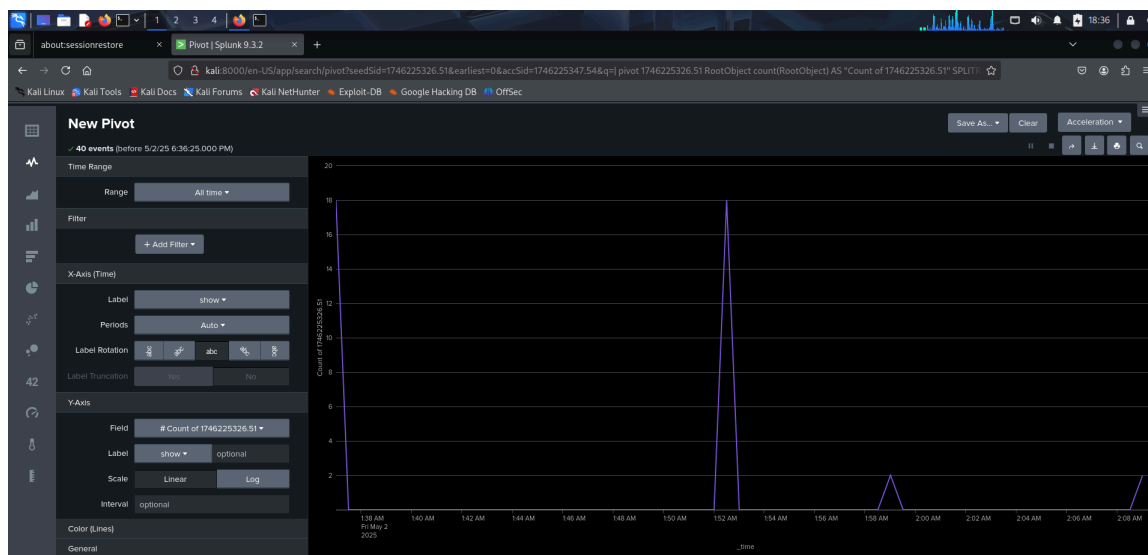
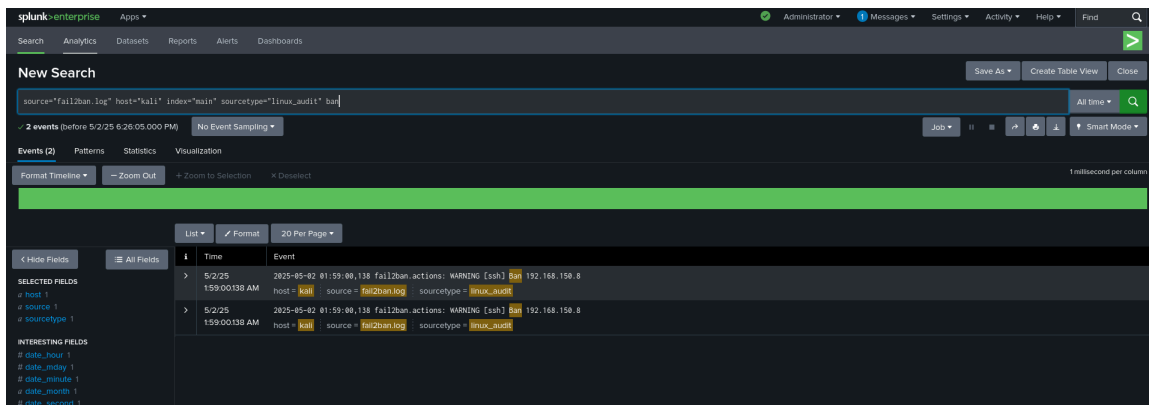
Ubuntu 14.04 LTS ubuntu tty1
ubuntu login: vagrant
Password:
Last login: Fri May 2 01:35:44 UTC 2025 on tty1
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

* Documentation:  https://help.ubuntu.com/
vagrant@ubuntu:~$ sudo fail2ban-client status ssh
Status for the jail: ssh
|- filter
| |- File list:          /var/log/auth.log
| |- Currently failed: 0
| `-- Total failed:     50
-- action
| |- Currently banned: 1
| `-- IP list:         192.168.150.8
`-- Total banned:      1
vagrant@ubuntu:~$ _
```

Step 4: Analyze Logs in Splunk

After implementing the Fail2Ban defense mechanism, we retrieved the updated log file `fail2ban.log` from the victim machine and uploaded it to Splunk. By searching for events with the keyword "Ban", we confirmed that the attacker's IP 192.168.150.8 was successfully banned, verifying that the defense was triggered.

Furthermore, the line chart below visualizes the number of SSH-related log events over time. A noticeable drop in activity occurred after the defense was enabled, indicating that repeated brute-force attempts were blocked by Fail2Ban.



Step 5: Compare Before and After

To evaluate the effectiveness of the implemented defense (Fail2Ban), we compared the log events **before** and **after** the defense was applied.

- **Before Defense (Screenshot 1):**

This screenshot from auth.log in Splunk shows multiple SSH login events, including both successful and failed attempts, which indicates the system was exposed to brute-force or repeated login attempts before any protection was in place.

- **After Defense (Screenshot 2):**

This screenshot from fail2ban.log confirms that Fail2Ban detected the suspicious activity and **banned** the attacker's IP address (192.168.150.8). This proves that the defense mechanism successfully mitigated the attack by preventing further SSH login attempts from that source.

